

Vibe Coding 安全守則

入門開發者必修的風險意識與責任邊界

核心觀念先講清楚

Vibe Coding 不是亂寫 code，而是「我不全懂，但我知道哪些東西我不能亂碰」

這不是在教你成為資安專家，而是建立基本的風險意識。就像開車不需要會修引擎，但一定要知道紅燈要停。

Vibe Coding 也是如此，你可以用 AI 快速開發，但必須清楚安全底線在哪裡。

 接下來的五大守則，是每個 vibe coder 都該內化的安全心法。

守則一：API Key 永遠不寫死在程式碼裡

1 為什麼這是第一條

只要把 key 寫在前端、GitHub、或貼到 ChatGPT，那把鑰匙就不再是你的了。

2 本機開發安全做法

- 使用 .env 檔案儲存
- .env 一定要加進 .gitignore
- 絕不直接寫在 code 裡

3 雲端部署正確方式

- 用平台的 Environment Variables
- 例如 Vercel、Railway、Render
- 或 Cloudflare Workers

程式碼可以給 AI 看，Key 不行

 關鍵認知：Key 是「權限」，不是「設定值」

守則二：前端只負責「請求」，不負責「保密」

✗ 常見新手誤區

「我只是做個小 app 而已，直接在前端呼叫 OpenAI 沒關係吧？」

這是最常見也最危險的誤解。只要在前端，使用者的瀏覽器、惡意腳本都看得到你的 Key。

✓ 關鍵認知

前端就像透明玻璃屋，任何放在裡面的東西都是公開的。

這不是技術問題，而是瀏覽器運作的基本原理。



前端責任

- 收集使用者輸入
- 顯示處理結果
- 提供互動介面



後端責任

- 儲存 API Key
- 實際呼叫 API
- 處理敏感邏輯

❗ Vibe coder 不一定要會寫後端，但一定要知道「我不能把大門鑰匙放在地毯下」

守則三：AI 生成的 code $\neq$ 安全的 code

這一條非常重要，AI 是強大的工具，但不會替你承擔風險。

1 AI 會幫你做的事

- 快速實現功能
- 串接 API 流程
- 生成基礎架構
- 解決語法問題

2 AI 不會負責的事

- 辨識安全漏洞
- 評估風險等級
- 承擔法律責任
- 處理真實事故

誰 deploy，誰負責 | 誰用 AI 寫，誰要檢查

高階主管不會知道所有細節，但他知道「出事要找誰」。Vibe coding 也是一樣：誰叫 AI 寫的，誰就要知道怎麼收尾。

❗ 這不是要嚇唬你，而是建立正確的責任認知。使用 AI 加速開發是好事，但最終按下部署按鈕的人，就是要為結果負責的人。

守則四：權限最小化，不要一次給 AI 全世界

✗ 常見錯誤做法

一個 Key 直接擁有所有權限，這就像給實習生公司保險櫃的鑰匙，風險太大了：

- 讀取資料
- 寫入資料
- 刪除資料
- 管理帳號
- 修改設定

✓ 正確心法

AI 是實習生，不是老闆

給 AI 或測試環境最小必要權限，就像你不會給實習生所有系統的最高權限一樣。

1

一個專案一把 key

不同專案使用獨立的 API Key，避免交叉影響

2

測試用、正式用分開

開發環境和生產環境使用不同的 key

3

不用的 key 直接刪除

專案結束或 key 洩漏時，立即撤銷權限

守則五：真實資料不要直接丟給 AI

這是最容易被忽略，卻可能造成最大傷害的一條。當你把資料貼給 AI 的那一刻，你就失去了對資料的完全控制。



使用者個資

Email、電話、地址等個人識別資訊



客戶名單

商業往來對象的任何相關資訊



內部文件

公司的營運、財務、策略文件



商業機密

專利、配方、未公開的產品資訊

教學與練習的正確做法

- Demo 使用假資料
- 教學使用 mock data
- 練習使用 sample 範例
- 絕不使用真實用戶資料測試



你敢寄給陌生人的資料，才能丟給 AI

在按下「送出」之前，先問自己：「如果這些資料出現在網路上，我能接受嗎？」如果答案是否定的，就不該使用真實資料。

我們在教的不是「資安」而是「風險意識與責任邊界」

Week 1 建立認知

Vibe Coding 是什麼 × 不是什麼

建立學員對這種開發方式的正確理解

Week 2 實作基礎

從 Demo 到可用產品，中間差在哪

教學員如何讓原型變成真正能上線的作品

Week 3-4 安全實踐

五大安全守則的實際應用

在真實專案中落實安全習慣

目標：不是把學員訓練成後端工程師或資安專家，而是：

- 知道自己能力的邊界
- 理解哪些風險需要專業處理
- 建立負責任的開發習慣
- 能夠辨識潛在的安全問題

AI 寫 code 根本不安全，這樣是害他們！

我們要學習的正是 vibe coding 的安全底線，讓大家知道什麼能做、什麼不能做，這本身就是對自己及未來的使用者負責任的起點。

我們的教學定位

培養具備風險意識的快速開發者，
而不是全端工程師。

就像教人開車不需要先會修引擎，
但一定要知道基本的行車安全。

學員能獲得的能力

能夠使用 AI 快速打造產品原型，同
時知道何時需要尋求專業協助，何
時該停下來思考風險。

這是務實且負責任的技能。

與傳統教學的差異

傳統課程教「如何做對」，我們會更
重視教「如何不做錯」。

兩者都重要，但後者常被忽略，卻
是 vibe coding 最關鍵的部分。

📌 最終論點：我們是在建立新的專業標準：一個適合 AI 協作時代的開發者素養。

總結：成為負責任的 Vibe Coder

- **API Key 永遠不寫死**
程式碼可以給 AI 看，Key 不行。
- **前端只負責請求**
不能把鑰匙放在門口。
- **AI 生成不等於安全**
誰 deploy，誰負責。
- **權限最小化原則**
AI 是實習生，不是老闆。
- **真實資料要保護**
敢寄陌生人的，才能給 AI。

最後提醒

Vibe Coding 的本質是「快速實現想法」，但不是「無視風險」。

這五大守則不是要限制你的創造力，而是讓你能夠更安心、更長久地使用 AI 開發。

記住：專業不只是會做很多事，更重要的是知道哪些事不該做。

